Vulnerability Management Policy

Effective Date:
April 10, 2026

Category:
Security

Scheduled Review:
April 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Purpose

The purpose of this policy is to establish a comprehensive vulnerability management program for the Commonwealth of Pennsylvania.

3. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

4. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

The Commonwealth shall employ a structured vulnerability management process that leverages risk-based prioritization and continuous monitoring to maintain the confidentiality, integrity, and availability of Commonwealth information systems.

This program ensures that vulnerabilities in Commonwealth IT systems are identified, evaluated, and remediated in a timely manner to reduce the risk of compromise to the confidentiality, integrity, and availability of Commonwealth IT assets. By proactively managing security flaws through patches and other mitigations, the Commonwealth aims to prevent data breaches, service disruptions, and other adverse events, framing patching as critical preventive maintenance for technology operations. This policy also provides a consistent framework to meet regulatory and compliance requirements.

Agencies shall implement this policy in accordance with the requirements defined in the Commonwealth's Vulnerability Management Standard.

4.1 Vulnerability Identification and Assessment

Asset Inventory and Classification: All agencies must maintain an up-to-date inventory of IT assets and their criticality. Assets should be classified based on their importance to Commonwealth missions and the sensitivity of data they handle (e.g. mission-critical systems, public-facing systems, high-value assets).

Vulnerability Scanning: The Commonwealth enterprise vulnerability scanning solutions (automated tools and manual methods) shall be used to continuously or periodically scan host systems, and network devices, for known vulnerabilities. Scan results are used to inform IT management and system administrators of identified weaknesses. Agencies shall ensure that all host systems under their purview are regularly scanned at least monthly. Scan results will be available to the Commonwealth Chief Information Officer, Commonwealth Chief Technology Officer, Commonwealth Information Security Officer, Agency Information Security Officer (ISO) and the Commonwealth's Enterprise Information Security Office (EISO) Vulnerability Management team for review. Detected vulnerabilities shall be entered into the approved Governance, Risk, and Compliance (GRC) tracking system as remediation tickets for tracking and oversight.

Vulnerability Severity Rating: The Commonwealth adopts the industry-standard Common Vulnerability Scoring System (CVSS) to measure and communicate the severity of security vulnerabilities. The EISO may adjust the severity level of a vulnerability (higher or lower) based on contextual factors, asset criticality or vendor ratings. If the EISO assigns a higher severity than the vendor or CVSS indicates, the EISO's rating shall take precedence for remediation scheduling.

Threat Intelligence and Exploit Activity: Threat intelligence and current exploit activity will be considered when assessing vulnerabilities such as those being actively exploited in the wild or included in threat advisories such as Zero-day or actively exploited critical vulnerabilities. This will include immediately implementing a scan of potentially affected systems.

5. Contact

Questions or comments may be directed via email to OA, IT Policy.

6. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy waiver shall be submitted via the enterprise IT policy waiver process. Refer to *IT Policy Governance Policy* for guidance.

7. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	04/10/2026	Base Document